

How to Write Up a Finding

The **Finding** section of our report is the "meat." This is where we get to show off what we found, how we exploited them, and give the client guidance on how to remediate the issues. The more detail we can put into each finding, the better. This will help technical teams reproduce the finding on their own and then be able to test that their fix worked. Being detailed in this section will also help whoever is tasked with the post-remediation assessment if the client contracts your firm to perform it. While we'll often have "stock" findings in some sort of database, it's essential to tweak them to fit our client's environment to ensure we aren't misrepresenting anything.

Breakdown of a Finding

Each finding should have the same general type of information that should be customized to your client's specific circumstances. If a finding is written to suit several different scenarios or protocols, the final version should be adjusted to only reference the particular circumstances you identified. "**Default Credentials**" could have different meanings for risk if it affects a DeskJet printer versus the building's HVAC control or another high-impact web application. At a minimum, the following information should be included for each finding:

- Description of the finding and what platform(s) the vulnerability affects
- Impact if the finding is left unresolved
- Affected systems, networks, environments, or applications
- Recommendation for how to address the problem
- Reference links with additional information about the finding and resolving it
- Steps to reproduce the issue and the evidence that you collected

Some additional, optional fields include:

- CVE
 - OWASP, MITRE IDs
 - CVSS or similar score
 - Ease of exploitation and probability of attack
 - Any other information that might help learn about and mitigate the attack
-

Showing Finding Reproduction Steps Adequately

As mentioned in the previous section regarding the Executive Summary, it's important to remember that even though your point-of-contact might be reasonably technical, if they don't have a background specifically in penetration testing, there is a pretty decent chance they won't have any idea what they're looking at. They may have never even heard of the tool you used to exploit the vulnerability, much less understand what's important in the wall of text it spits out when the command runs. For this reason, it's crucial to guard yourself against taking things for granted and assuming people know how to fill in the blanks themselves. If you don't do this correctly, again, this will erode the effectiveness of your deliverable, but this time in the eyes of your technical audience. Some concepts to consider:

- Break each step into its own figure. If you perform multiple steps in the same figure, a reader unfamiliar with the tools being used may not understand what is taking place, much less have an idea of how to reproduce it themselves.
- If setup is required (e.g., Metasploit modules), capture the full configuration so the reader can see what the exploit config should look like before running the exploit. Create a second figure that shows what happens when you run the exploit.

Figure 19: Cracking a Password with Hashcat

Rationale

The "bad" example gives the client no way to remediate this issue without spending a lot of money that they may not have. While the commercial tool may be the easiest solution far and away, many clients will not have the budget to do that and need an alternative solution. The alternative solution may be a bandaid or extraordinarily cumbersome, or both, but it will at least buy the client some time until the vendor has released an official fix.

Selecting Quality References

Each finding should include one or more external references for further reading on a particular vulnerability or misconfiguration.

Some criteria that enhance the usefulness of a reference:

- A vendor-agnostic source is helpful. Obviously, if you find an ASA vulnerability, a Cisco reference link makes sense, but I wouldn't lean on them for a writeup on anything outside of networking. If you reference an article written by a product vendor, chances are the article's focus will be telling the reader how their product can help when all the reader wants is to know how to fix it themselves.

A thorough walkthrough or explanation of the finding and any recommended workarounds or mitigations is preferable. Don't choose articles behind a paywall or something where you only get part of what you need without paying.

- Use articles that get to the point quickly. This isn't a recipe website, and no one cares how often your grandmother used to make those cookies. We have problems to solve, and making someone dig through the entire NIST 800-53 document or an RFC is more annoying than helpful.
- Choose sources that have clean websites and don't make you feel like a bunch of crypto miners are running in the background or ads pop up everywhere.
- If possible, write some of your own source material and blog about it. The research will aid you in explaining the impact of the finding to your clients, and while the infosec community is pretty helpful, it'd be preferable not to send your clients to a competitor's website.

Example Findings

Below are a few example findings. The first two are examples of issues that may be discovered during an Internal Penetration Test. As you can see, each finding includes all of the key elements: a detailed description to explain what is going on, the impact to the environment if the finding is left unfixed, the hosts affected by the issue (or the entire domain), remediation advice that is generic, does not recommend specific vendor tools and gives several options for remediation. Finally, the reference links are from well-known, reputable sources that will likely not be taken down anytime soon as a personal blog may.

A note on the formatting: This could potentially be a hotly contested topic. The example findings here have been laid out in a tabular format, but if you've ever worked in Word or tried to automate some of your report generation, you know that tables can be a nightmare to deal with. For this reason, others opt to separate sections of their findings with different heading levels. Either of these approaches is acceptable because what is important is whether your message gets across to the reader and how easy it is to pick out the visual cues for when one finding ends and another begins; readability is paramount. If you can accomplish this, colors, layout, order, and even section names can be adjusted.

Weak Kerberos Authentication ("Kerberoasting")

1. Weak Kerberos Authentication ("Kerberoasting") - High	
CWE	CWE-522

CVSS 3.1 Score	9.5
Description (Incl. Root Cause)	In an Active Directory (AD) environment, Service Principal Names (SPNs) are used to uniquely identify instances of a Windows service. Kerberos authentication requires that each SPN be associated with one service account (Active Directory user account). Any authenticated AD user can request one or more Kerberos Ticket-Granting Service (TGS) tickets from the domain controller for any SPN accounts. These tickets are encrypted with the associated AD account's NTLM password hash. They can be brute-forced offline using a password cracking tool such as Hashcat if a weak password is used along with the RC4 encryption algorithm. If AES encryption is in use, it will take more resources to "crack" a ticket to reveal the account's clear-text password, but it is possible if weak passwords are in use.
Security Impact	A successful Kerberoasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain.
Affected Domain	• INLANEFREIGHT.LOCAL
Remediation	Where possible eliminate SPNs in the environment in favor of Group Managed Service Accounts (gMSA) which are not subject to this type of attack. If migration to gMSAs is not possible the following steps will help mitigate the risk of this attack: • Enable AES Kerberos encryption instead of RC4 • Use strong 25+ character passwords for service accounts and rotate them periodically • Limit the privileges of service accounts and avoid creating SPNs tied to highly privileged accounts such as Domain Administrators
External References	https://attack.mitre.org/techniques/T1558/003/

Tomcat Manager Weak/Default Credentials

2. Tomcat Manager Weak/Default Credentials - High	
CWE	CWE-521
CVSS 3.1 Score	9.5
Description (Incl. Root Cause)	An Apache Tomcat Server was found that was exposing the <i>Tomcat Manager</i> login URL and using weak/default credentials to enter the <i>Manager</i> (admin) backend.
Security Impact	An attacker who gains access to the <i>Tomcat Manager</i> area can upload a malicious application via a WAR file containing custom JSP code. This code can be used to run arbitrary commands on the underlying server in the context of the service account that the Apache Tomcat instance runs under. This Tomcat instance was running under a local service account assigned privileges that can be leveraged to escalate to the all-powerful NT AUTHORITY\SYSTEM account and gain complete control over the server, potentially gaining access to credentials and other sensitive data.
Affected Host(s)	• 192.168.195.205 (8080/TCP)
Remediation	• Restrict access to the Tomcat Manager URL to either localhost or only select IP addresses if this URL does need to be accessed remotely by administrators. • Change the default administrator account name to something unique and set a strong, randomized password that does not appear in any wordlists as the Tomcat Manager page uses Basic Authentication, which has no inherent protections against password brute-forcing attacks.
External References	https://attack.mitre.org/techniques/T1078/001/

Poorly Written Finding

Below is an example of a poorly written finding which has several issues:

- Formatting is sloppy with the CWE link
- No CVSS score is filled in (not mandatory, but if your report template uses it, you should fill it in)
- The Description does not clearly explain the issue or root cause
- The security impact is vague and generic
- The Remediation section is not clear and actionable

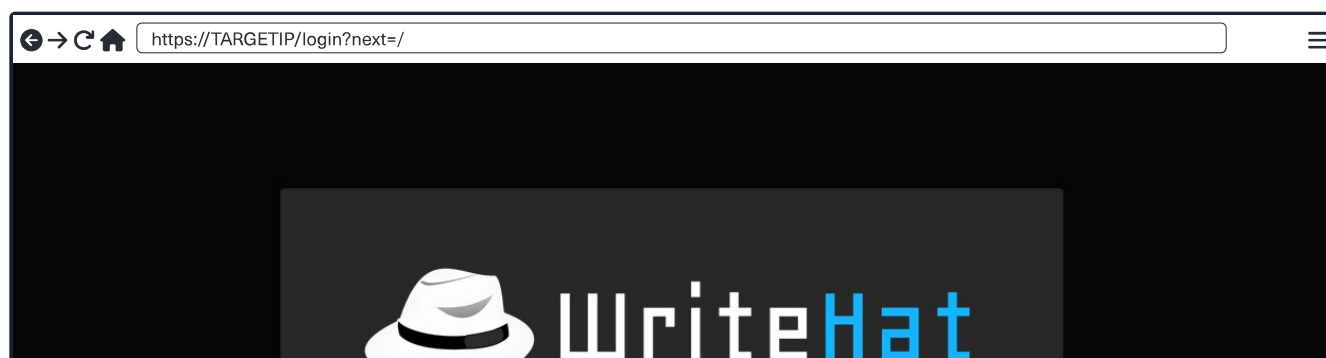
If I am reading this report, I can see that this finding is bad (because it's red), but why do I care? What do I do about it? Each finding should present the issue in detail and educate the reader on the issue at hand (they may very likely have never heard of Kerberoasting or some other attack). Clearly articulate the security risk and **why** this needs to be remediated and some actionable remediation recommendations.

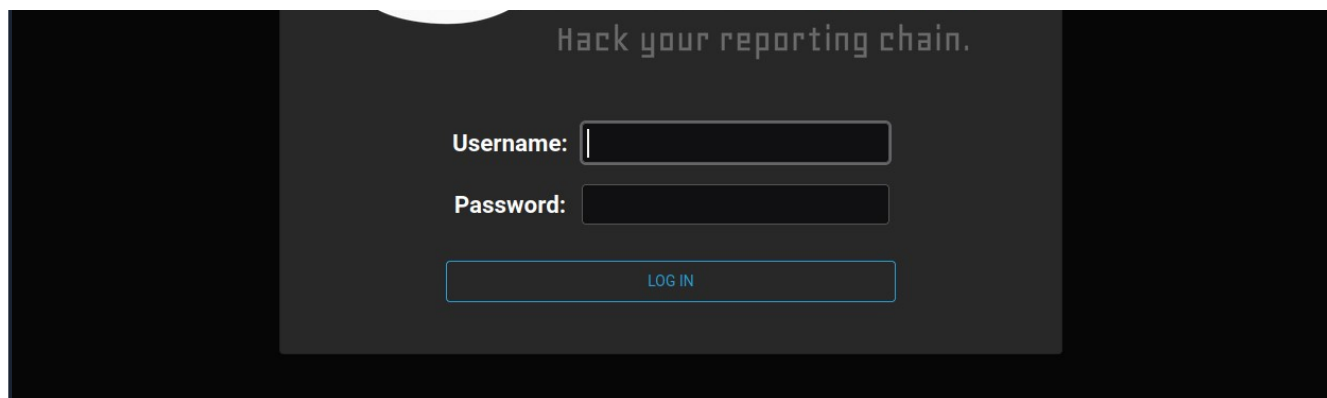
2. Kerberoasting - High	
CWE	https://cwe.mitre.org/data/definitions/522.html
CVSS 3.1 Score	
Description (Incl. Root Cause)	Any Domain User can grab password hashes for Service Principal Name Accounts using Rubeus or PowerView and then crack them to get the users' password with Hashcat.
Security Impact	Kerberoasting could lead to unauthorized access or Domain Admin.
Affected Domain	• INLANEFREIGHT.LOCAL
Remediation	• Delete all SPN accounts from the domain • Make SPN account passwords 25+ characters • Use gMSA instead of SPNs if possible
External References	https://attack.mitre.org/techniques/T1558/003/

Hands-On Practice

The target VM that can be spawned in this section has a copy of the [WriteHat](#) reporting tool running. This is a helpful tool for building a findings database and generating customized reports. While we do not endorse any one specific tool in this module, many reporting tools are similar, so playing around with WriteHat will give you a good idea of how these types of tools work. Practice adding findings to the database, building and generating a report, etc. We prepopulated the findings database with some common findings categories, and some of the findings included in the sample report attached to this module. Experiment with it as much as you like and practice the skills taught in this section. Keep in mind that anything you enter into the tool will not be saved once the target expires, so if you write up any practice findings, make sure to keep a copy locally. This tool will also be helpful for the hands-on guided lab at the end of this module.

Once the target spawns, browse to <https://< target IP >> and log in with the credentials `htb-student:HTB_@cademy_stdnt!`.





Practice writing up findings and exploring the tool. You may even decide you like it enough to use it as part of your workflow. One idea would be to install a copy locally and practice writing findings for issues you discover in Academy module labs or boxes/labs on the HTB main platform.

Nearly There

Now that we've covered how to stay organized during a penetration test, types of reports, the standard components of a report, and how to write up a finding, we have some reporting tips/tricks to share with you from our collective experience in the field.

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

40ms

Terminate Pwnbox to switch location

[Start Instance](#)

∞ / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

[Download VPN
Connection File](#)

Target: [Click here to spawn the target system!](#)



RDP to with user "htb-student" and password "HTB_@cademy_stdnt!"

+ 1

"An attacker can own your whole entire network cause your DC is way out of date. You should really fix that!". Is this a Good or Bad remediation recommendation? (Answer Format: Good or Bad)

[Submit](#)

Optional Exercises

Challenge your understanding of the Module content and answer the optional question(s) below. These are considered supplementary content and are not required to complete the Module. You can reveal the answer at any time to check your work.

Target: [Click here to spawn the target system!](#)

Connect to the testing VM using Xfreerdp and practice writing findings based on the evidence in the Obsidian notebook. Use your penetration testing skills to gather additional evidence for the findings where evidence is not provided. Type DONE as your answer when you have finished.

[Submit](#)[Reveal Answer](#)[← Previous](#)[Next →](#)[Resources](#)

[? Go to Questions](#)

Table of Contents

Intro

Introduction to Documentation & Reporting



Preparation

Notetaking & Organization



Types of Reports



Components of a Report



Reporting

[How to Write Up a Finding](#)

Reporting Tips and Tricks

Next Steps

Documentation & Reporting Practice Lab

Beyond this Module - Documentation & Reporting

My Workstation

O F F L I N E

Start Instance

/ 1 spawns left